00260

Sri Lanka Institute of Information Technology

B.Sc. Honours Degree in Information Technology

Final Examination
Year 3, Semester 2 (2024)

IT3070 – Information Assurance & Security

Duration: 2 Hours

November 2024

Instructions to Candidates:

- This paper has FOUR questions.
- Answer all questions in the booklet given.
- This paper is preceded by a 10-minute reading period. The supervisor will indicate when answering may commence.
- The total mark for the paper is 100.
- This paper contains SEVEN pages, including the cover page.
- Faculty approved calculators are allowed.

Question 1 (25 Marks)

a. Read the following case study and answer the questions.

"SmartHomeX, a popular smart home system, integrates various home appliances, security cameras, and door locks into a single mobile application. Recently, researchers at CyberTech Labs discovered a serious weakness in the system's API authentication mechanism. This allows attackers to bypass authentication by sending a specially crafted request, exploiting a weak token verification process. Once authenticated, the attacker can control all connected devices within the home, including unlocking doors or disabling security cameras. SmartHomeX has released a security patch to address the beforementioned vulnerability. However, CyberTech has noticed many homes are still running on the older firmware.

i. Identify the Vulnerability and the Risk in the case study given.

(5 Marks)

ii. Suggest a countermeasure homeowners can implement to prevent this type of attack.

(4 Marks)

b. The three fundamental bases of information security are represented in the C.I.A triad. Identify the highest priority security C.I.A requirement associated with each given scenario. Only mention one security requirement for each scenario.

i. You are managing the security of an online exam platform used by schools and universities. Ensuring that the platform remains functional during exam periods is essential to avoid disruptions and delays for students taking exams

ii. You are responsible for securing a payment processing system for a large retail chain. It is crucial to ensure that all payment transactions remain accurate and unaltered, as any discrepancies could lead to financial losses or disputes.

iii. You oversee cybersecurity for a government agency that handles classified national security information. Any unauthorized access or exposure of classified data could pose a significant threat to national security.

iv. You work for a financial institution handling online banking transactions. It is essential to ensure that financial data, such as account balances and transaction details, remain accurate and unaltered during data transmission and storage.

(8 Marks)

c. Attacks can be categorized as 'Active' & 'Passive' or 'Insider' & Outsider'. Map the given attack scenarios to correct categories. Answer the question using the given table template.

i. **Mark** works as a database administrator for a retail company. He uses his access privileges to extract customer credit card data from the internal system and sells it on the dark web.

ii. **Jane** notices a vulnerable public FTP server at a local library. She downloads sensitive documents stored on the server without alerting the library staff to the vulnerability.

iii. **Steve** is an employee at a software company. He is planning to leave the company and install a backdoor on the company's servers, allowing him unauthorized access after his departure.

iv. A **hacker** installs a keylogger on public library computers, capturing login credentials of users who log in to their online accounts, without making any modifications to the computer systems.

Answer Template:

Scenario	Active / Passive	Insider / Outsider
i		

(8 Marks)

Question 2 (25 Marks)

a. Information security controls can be categorized as given below. Answer the question using the given table template.

Based on the Type of Control: Technical, Physical, Administrative
Based on the Objective of Control: Preventive, Detective, Corrective, Deterrent

Map the given security controls to correct control categorization. Answer the question using the given table template.

i. A firewall that blocks unauthorized inbound traffic from entering the organization's internal network.
ii. A steel bolted door with a sophisticated lock at the data center entrance.
iii. Data backup and recovery application in place to restore systems after a ransomware attack or hardware failure.
iv. A training program that educates employees on security policies and how to recognize phishing emails.

Answer Template:

Control	Type of Control	Objective of Control
i		

(8 Marks)

b. 'Quantitative Risk Analysis' attempts to assign independent monetary values to system components, therefore offers direct risk cost projection. The following information is extracted from a risk evaluation done by an enterprise.

Starline Logistics Ltd. is a leading supply chain and logistics company offering comprehensive transportation and warehousing services across the country. An assessment was carried out to identify critical IT assets vital to the company's operations, along with their values. The Fleet Management System Server is valued at Rs. 1,200,000/=. It has been determined that this server is vulnerable to a sophisticated malware attack. Data gathered during the evaluation revealed that the server has an exposure factor of 30% for this threat, and the malware attack is estimated to occur once every six months.

i. Calculate the Single Loss Expectancy (SLE) for the above incident.

(3 Marks)

ii. Calculate the Annual Loss Expectancy (ALE) for the above incident.

(3 Marks)

c. Read the case study, and answer the questions given below.

"Tech Innovations Inc. is a leading technology company specializing in the development of cutting-edge software solutions for various industries. The company's flagship product, a cloud-based data analytics platform, has gained widespread adoption among enterprise clients worldwide. Tech Innovations Inc.'s cloud-based data analytics platform contains highly sensitive proprietary algorithms, customer data, and intellectual property crucial to the company's competitive advantage and reputation. Currently they consider their excellent reputation as the biggest competitive advantage in the market.

The hacker group XQC conducts reconnaissance activities to identify vulnerabilities in Tech Innovations Inc.'s IT infrastructure and systems. Exploiting an old injection vulnerability in the data analytics platform's authentication system, they gain unauthorized access to the platform. Hacker group then exfiltrate sensitive customer data and proprietary algorithms stored on the platform. The breach leads to financial losses, damage to the company's reputation, and legal liabilities due to regulatory non-compliance. Additionally, the incident triggers a loss of trust among existing customers and hampers the company's ability to acquire new clients, resulting in a decline in revenue and market share."

i. Create an OCTAVE risk assessment framework-based threat profile for the above case study.

(5 Marks)

ii. Asses the most important impact area for the above organization. Justify your selection.

(3 Marks)

d. What is the complexity of brute forcing a 12-bit symmetric encryption key?

(3 Marks)

Question 3 (25 Marks)

a. Answer the questions based on the given case study below.

The National Archives Department (NAD) of a government organization is responsible for storing and managing sensitive digital records, including classified documents, confidential communication, and legal agreements. To ensure the security of these digital records, the department has been using the Data Encryption Standard (DES) for encryption over the past several years. DES was originally chosen due to its widespread adoption and its ability to provide a layer of encryption.

i. Justify why NAD should not be using DES for encrypting sensitive digital records.

(3 Marks)

ii. Recommend an alternative algorithm the department can use to encrypt the sensitive records without compromising the speed.

(3 Marks)

b. Public Key Cryptography plays an important role in securing the overall internet infrastructure.

i. Briefly explain how Public Key Cryptography can be used to address the key distribution problem of symmetric key encryption.

(2 Marks)

ii. With the aid of a diagram, propose a way to create a digital signature for a message which can be verified by the receiving party.

(4 Marks)

c. You are tasked with creating an Access Control Matrix (ACM) for the Marketing and Sales departments of the XYZ Corporation. Using the information provided below, create an Access Control Matrix that represents the access rights of users (U1, U2, U3, U4) to resources (R1, R2, R3, R4). Use "R" to denote read access, "W" for write access, "X" for execute access, and "-" to indicate no access. Assume that users have no access by default.

Users:
U1 (Marketing Manager)
U2 (Sales Representative)
U3 (Intern)
U4 (External Consultant)

Resources:
R1 (Marketing Campaign Data)
R2 (Sales Reports)
R3 (Client Database)
R4 (Data Analytic Software)

Access Control Rules:

1. The Marketing Manager has read and write access to Marketing Campaign Data and Sales Reports and read access to the Client Database. He is the only person who can also use the Data Analytics software with no restriction.
2. The Sales Representative has read access to Sales Reports and write access to the Client Database.
3. The Intern has read access to Marketing Campaign Data and Sales Reports, but no access to the Client Database.
4. The External Consultant only has read access to Marketing Campaign Data.

Answer Template:

	R1	R2	R3	R4
U1				
U2				
U3				
U4				

(9 Marks)

d. Access control is the prevention of unauthorized use of a resource. Propose the most suitable access control policy out of DAC, MAC and RBAC for the given scenarios below.

i. In a large corporation, the corporate intranet contains sensitive documents and internal tools, with users categorized as Employees, Managers, and Executives. Employees have read access to general documents, Managers can read and write project files and manage team access, while Executives have full access to all documents, including financial reports.

ii. In a government agency managing classified information, access is strictly controlled based on security clearance levels: Top Secret, Secret, and Confidential. Users with Top Secret clearance can access all classified data, those with Secret clearance can access secret and unclassified information, and users with Confidential clearance are limited to confidential and unclassified data

(4 Marks)

Question 4 (25 Marks)

a. You have been appointed to conduct an awareness campaign regarding the importance of passwords in a corporate environment. Suggest three key messages you want to include in the awareness program.

(6 Marks)

b. Read the case study given below and answer the following questions.

A company's firewall is configured to protect the subnet 10.0.20.0 /24. Internal hosts may access all external websites (port 80) except 203.45.67.89. All external hosts may access the internal web server (port 80) on 10.0.20.50, and all other activity is to be blocked.

i. Create a firewall table to address the above requirements. (Include the following columns in the table:[Rule Number, Source IP, Source Port, Destination IP, Destination Port, Protocol, Action]

(10 Marks)

ii. The company expects to create a separate screened-subnet to protect a sensitive file server. This server needs protection from both inside and outside. Recommend the most suitable firewall topology to address this requirement. You may use a diagram if necessary.

(4 Marks)

c. Compare the functionality of the regular service mode and alternate mode with respect to disaster recovery and business continuity of an organization.

(5 Marks)

--End-of-Question-Paper--